Secure your website: accounts, DNS, hosting, pipeline and third parties

A vendor-neutral programme to harden a public website: phishing-resistant accounts, domain verification and DNS hygiene, TLS and security headers, CI/CD pinning and least privilege, first-party code and third-party scripts, integrations and privacy, monitoring, then backup and a prioritised checklist. Documentation verified; not lab-tested.

8 phases | 15 steps | Tick each item when its "done when" criterion is true

Phase 1 Lock the accounts that can rewrite the site about Half a day

- [ ] **1.1 Turn on phishing-resistant MFA on registrar, host, git and SaaS**
  Registrar, DNS host, git forge, hosting/CDN, newsletter and analytics each show a passkey or hardware key enrolled, with recovery codes stored offline
- [ ] **1.2 Inventory sessions, OAuth apps and long-lived tokens**
  A dated inventory lists active sessions, OAuth apps, PATs/deploy keys and CI secrets with owners and expiry
- [ ] **1.3 Protect the registrar and DNS console like production Tier 0**
  Registrar login has MFA, transfer/registrar lock is on, and who can create DNS records is named

Phase 2 Domain, DNS, DNSSEC, CAA and TLS about Half a day to 1 day

- [ ] **2.1 Verify the custom domain with the publishing host**
  The host shows the apex (and www if used) as verified, and the verification TXT remains in DNS
- [ ] **2.2 Publish CAA and finish DNSSEC properly — or turn it off cleanly**
  CAA allows only the CAs you intend; DNSSEC either has a matching DS at the parent or is fully disabled
- [ ] **2.3 Enforce HTTPS end-to-end**
  HTTP redirects to HTTPS, the certificate covers the names users type, and weak TLS is disabled at the edge

Phase 3 Hosting and browser security headers about About 1 day

- [ ] **3.1 Know what your host can and cannot set**
  A short matrix lists which headers the origin can set versus which need a CDN or platform config
- [ ] **3.2 Self-host first-party assets; SRI for any third-party URL**
  Third-party script and stylesheet tags are removed, self-hosted, or carry integrity plus crossorigin

Phase 4 Harden the publishing pipeline about Half a day to 1 day

- [ ] **4.1 Pin Actions to full commit SHAs (or adopt a lockfile)**
  Every uses: line references a full-length commit SHA or a workflow lockfile, not a floating major tag
- [ ] **4.2 Least-privilege tokens, rulesets and secret scanning**
  Default GITHUB_TOKEN is read-only; write permissions are job-scoped; secret scanning and push protection are on; the default branch blocks force-push and deletion

Phase 5 Code patterns and third-party JavaScript about Half a day

- [ ] **5.1 Ban the usual DOM and XSS footguns in first-party JS**
  Review finds no eval/new Function/document.write; innerHTML only with escaped data; target=_blank uses rel=noopener noreferrer
- [ ] **5.2 Maintain a bill of what the browser loads**
  A short inventory lists every script, connect and image endpoint the browser hits in production

Phase 6 Integrations, forms, analytics and privacy about Half a day

- [ ] **6.1 Align privacy text with newsletter, forms and analytics reality**
  Privacy text matches cookies, localStorage, processors and regions; forms POST only to endpoints allowed by CSP form-action

Phase 7 Monitoring and recurring checks about 1–2 hours setup; quarterly thereafter

- [ ] **7.1 Run external scoreboards and keep the artefacts**
  Dated results exist from SSL Labs (or equivalent), SecurityHeaders or Observatory, and a passive ZAP scan against your own site

Phase 8 Backup, recovery and prioritised checklist about Half a day

- [ ] **8.1 Recovery drill and prioritised order of work**
  Offline notes cover registrar, DNS, git and host recovery; the prioritised checklist below is assigned to named owners

Owner	Change / ticket	Date completed

Original checklist by Tenant Recipes, an independent project not affiliated with Microsoft or any vendor. Every step, its actions, pitfalls and the official sources it was checked against are on https://tenantrecipes.com/guides/secure-your-website.html. Time estimates are our own planning figures. Confirm against the linked sources and test in a pilot before production.